

PROVA DE CONCEITO: ATAQUES DE SUBGRUPO NO DIFFIE-HELLMAN

ATAQUE DE CONFINAMENTO (LIM-LEE) & RECONSTRUÇÃO VIA CRT — CRYPTOPALS CHALLENGE 57

Autor: [Seu Nome / Matrícula] • Especialização: Segurança Cibernética • Artigo de Referência: Valenta et al. (NDSS 2017)

96%	3.813	5%
TAXA DE VULNERABILIDADE	REQUISIÇÕES DE ATAQUE	FALHA DE ENTRADA EXTREMA
Dos servidores HTTPS testados na Internet real que falharam em validar chaves no subgrupo correto.	Consultas ativas enviadas contra o balanceador da Amazon (ELB) para recuperar 17 bits da chave privada de teste.	Dos servidores aceitaram chaves públicas absurdas (-1, 0, 1), enfraquecendo drasticamente o segredo gerado.

A MATEMÁTICA DA VULNERABILIDADE & CONFINAMENTO

No Diffie-Hellman clássico, a chave privada de Bob x está protegida pelo problema do Logaritmo Discreto. No entanto, em grupos que utilizam primos não seguros ou parâmetros frágeis do tipo DSA, a ordem $p - 1$ do grupo possui um cofator $j = (p - 1)/q$ que é facilmente fatorável em pequenos primos r_i (smooth cofactor).

Se o sistema de Bob não realizar a **validação de chaves públicas** recebidas, um atacante (Eve) pode gerar uma chave pública maliciosa h de ordem pequena r :

- $h = g_{\text{rand}}^{((p-1)/r)} \bmod p$ (onde $h^r \equiv 1 \bmod p$)

Ao enviar h , Bob calcula o segredo compartilhado como $K = h^x \bmod p$. Pela álgebra de grupos cíclicos, K fica restrito ao subgrupo de tamanho r . O segredo K só assume r valores possíveis offline, permitindo que a Eve decifre o valor de $x \bmod r$ via oráculos de MAC em frações de segundo.

A Reconstrução de Chave Completa (CRT):

Ao interagir sucessivamente com os subgrupos pequenos, Eve acumula um conjunto de congruências lineares: $x \equiv a_i \bmod r_i$. Uma vez que o produto dos módulos acumulados é estritamente maior que a ordem do gerador ($\prod r_i > q$), o **Teorema Chinês do Resto (CRT)** unifica os pedaços e restaura a chave privada completa x de Bob de forma determinística.

ARQUITETURA DO LABORATÓRIO (PROGRAMA 4)

Para demonstrar esta fragilidade e sua devida mitigação na prática, foi desenvolvido um laboratório completo de sockets de rede em Python, operando em portas locais distintas no sistema operacional:

Script / Entidade	Porta	Função no Handshake
bob_vulnerable.py	TCP 8080	Calcula segredos e retorna MAC sem checar subgrupo.
bob_secure.py	TCP 8081	Valida chaves recebidas; aborta se falhar no teste $y^q \equiv 1$.
alice_legitimate.py	Cliente	Alice honesta; gera chaves válidas e funciona em ambos.
eve_attacker.py	Cliente	Interage com as portas; quebra chaves ou é bloqueada.

Resultados dos Testes Práticos:

- Cenário Vulnerável (8080):** O script do atacante (Eve) completa o roubo de uma chave de 39 dígitos (128 bits) em menos de 2 segundos.
- Cenário Protegido (8081):** Bob Seguro detecta que a primeira chave de teste $y^q \bmod p \neq 1$, abortando a conexão imediatamente. O ataque falha.

CONTRAMEDIDAS CRÍTICAS E PRÁTICAS DE DEFESA RECOMENDADAS

1. Validação de Subgrupos (Subgroup Validation): Esta é a contramedida primária e mais eficiente demonstrada no *bob_secure.py*. O servidor DEVE validar a chave pública recebida y antes de calcular o segredo compartilhado. Para isso, ele realiza duas checagens matemáticas:

- **Intervalo Válido:** Verificar se $1 < y < p - 1$.

- **Validação de Ordem:** Calcular se $y^q \equiv 1 \pmod{p}$. Se falhar, a chave não pertence ao subgrupo seguro e a sessão deve ser imediatamente destruída.

2. Limpeza do Cofator (Cofactor Clearing): Alternativamente ou como redundância, o servidor pode computar o segredo elevando a chave recebida ao cofator j antes de usar a chave privada: $K = (y^j)^x \pmod{p}$. Isso projeta qualquer elemento recebido para dentro do subgrupo seguro de ordem prima q , neutralizando matematicamente os subgrupos pequenos por elevação à potência do cofator (reduzindo a componente maliciosa a 1).

3. Exponentes Efêmeros (Single-use Exponents): Impedir a reutilização de chaves privadas estáticas (usar Diffie-Hellman Efêmero - DHE) de modo que a chave privada mude a cada conexão. Isso frustra Eve, pois ela não consegue acumular congruências lineares consecutivas necessárias para o cálculo do Teorema Chinês do Resto.